

Creating/Renaming Experiment with Large Number of Integers in Name Leads to DOS in UI in mlflow/mlflow

✓ Valid

Reported on Jun 12th 2024

Description

The vulnerability allows the creation of an experiment with a large number of integers in its name due to the lack of a limit on the experiment name, causing the MLflow UI panel to become unresponsive.

Proof of Concept

```
1) Create or rename an experiment with a large number of integers (I've tried with
2) Refresh the page. Done.
```

Video POC:

<https://drive.google.com/file/d/10oOUa96hfUDv1Ko253vJFetLBxgGtKfa/view?usp=sharing>

Additional Info: There is also no character limit exist in `artifact_location` parameter while creating the experiment.

Impact

Unresponsive UI

Exploiting this vulnerability can cause the MLflow UI to become unresponsive, preventing users from accessing or managing their experiments effectively.

Potential Denial of Service

The unresponsive UI can lead to a denial of service, disrupting workflows and hindering the ability to track and manage experiments.

Workflow Disruption

This issue can significantly disrupt workflows, especially in environments where MLflow is heavily relied upon for collaborative machine learning experiment management.

Degraded User Experience

The overall user experience is degraded, causing frustration and inefficiency for users trying to manage and analyze their experiments.

Occurrences



client.py L1246-L1298



experiments.py L115-L121



run_info.py L104-L106

run_name

References

- <https://huntr.com/bounties/8ec14991-ee35-493d-a8d3-21a1cfd57869>



We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago



A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



M Nadeem Qazi modified the report 2 years ago



We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



We have sent a follow up to the **mlflow** team. We will try again in 4 days. 2 years ago



We have sent a second follow up to the **mlflow** team. We will try again in 7 days. 2 years ago



We have sent a third follow up to the **mlflow** team. We will try again in 14 days. 2 years ago



M Nadeem Qazi commented 2 years ago

Researcher

@admin Any Update ?



M Nadeem Qazi modified the report 2 years ago



We have sent a fourth follow up to the **mlflow** team. We will send a final notification 48 hours before report publication. 2 years ago

We'll work on a fix for this unexpected exploit.

  A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago

 The scheduled publication date was automatically extended from 10th Sep 2024 to 17th Sep 2024 due to the maintainers acknowledgement of the report 2 years ago

 This report has now been passed to internal triage and should be resolved within 14 days. 2 years ago



Marcello commented 2 years ago

Admin

We personally wouldn't consider this a vulnerability. Unless the mlflow maintainers comment they do, we're going to mark this as informational once we're closer to the publication date.



M Nadeem Qazi commented 2 years ago

Researcher

@Admin @maintainer already acknowledged the vulnerability, and passed the report to internal team.



 **Marcello** modified the Severity from High (7.5) to Medium (5.3) 2 years ago

 The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



 **Marcello** validated this vulnerability 2 years ago

 **mnqazi** has been awarded the disclosure bounty 

 The fix bounty is now up for grabs

 The researcher's credibility has increased: +7

 **CVE-2024-6838** assigned to this report. 2 years ago

 We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours a year ago

 We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

 This vulnerability has now been published a year ago

 **CVE-2024-6838** has now been published 10 months ago

CVE
CVE-2024-6838
Published

Vulnerability Type
CWE-400: Denial of Service

Severity
Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	Low

[Open in visual CVSS calculator](#)

Registry
Other

Affected Version
v2.13.2

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$125 to \$175

Fix Bounty
\$31.25

Found by



M Nadeem Qazi

@mnqazi

LIGHTWEIGHT



